# Hệ Thống Lý Dự Án Đầu Tư Công thiết kế chi tiết

Baseline 1.3 | 22/10/2026. Tài liệu này mô tả hợp đồng thực thi và thuật toán trọng yếu. Các tệp OpenAPI/SQL đi kèm là baseline kỹ thuật cần mở rộng trong sprint, không phải backend đã hoàn thành.

## Quy ước dữ liệu

ID dùng UUID; code nghiệp vụ là unique theo tenant/loại và có thể hiển thị riêng. Timestamp lưu UTC timestamptz, ngày nghiệp vụ dùng date và calendar_version. Tiền VND lưu numeric(24,0) tại ledger; tiền ngoại tệ numeric(24,6) kèm currency/FX; trình bày triệu đồng bằng chia chính xác 1.000.000. API truyền money dưới dạng chuỗi decimal, không float JavaScript. Rate và tỷ lệ lưu/compute numeric, chỉ làm tròn khi hiển thị.

Mọi row mutable có version bigint, created_at/by, updated_at/by; archive/soft-delete có deleted_at/reason. Dữ liệu được phê duyệt có immutable revision, effective dates và supersedes_id. Audit append-only gồm actor, impersonator nếu có, tenant, action, resource, before/after hoặc diff được redact, reason, request_id, timestamp, IP/thiết bị phù hợp chính sách. Bí mật, token và toàn bộ nội dung đề án không ghi vào audit.

## Từ điển dữ liệu báo cáo

report_revision: id UUID; tenant_id UUID; project_id UUID; period_id UUID; plan_version_id UUID; revision integer >0; status enum; version bigint; submitted_at timestamptz nullable; accepted_at nullable; supersedes_id nullable; amendment_reason text; source_kind enum manual/import/integration; payload_hash char64. Unique tenant/project/period/revision; partial unique current accepted theo business key.

funding_snapshot_line: report_revision_id; capital_bucket [CURRENT_YEAR,CARRYOVER,OTHER]; budget_level [CENTRAL,LOCAL]; allocated_vnd; disbursed_cumulative_vnd; ctmtqg_subset_vnd nullable; next_month_registered_vnd; next_month_ctmtqg_subset_vnd nullable; original_source_year nullable; source_reference. CTMTQG chỉ áp nhóm được chính sách cho phép; null nghĩa không áp dụng/chưa khai báo, khác 0. Giá trị âm không hợp lệ trừ bút toán điều chỉnh ở ledger có lý do.

progress_snapshot: construction_value_vnd, acceptance_value_vnd, treasury_submitted_value_vnd, preparing_dossier_value_vnd, measurement_basis [PERIOD,YTD,PROJECT_TO_DATE], as_of_date. Cần owner xác nhận basis vì nguồn demo chưa đủ rõ. Không suy luận nghiệm thu phải ≤ vốn giao năm trong mọi trường hợp; validation dùng basis và ngưỡng đúng loại.

reporting_period: type, code, start_date, end_date, deadline_at, locked_at, calendar_version. Lịch tuần cấu hình theo tenant; khóa date range không chồng lấn trong cùng calendar/type. Period mang fiscal_year tách năm lịch nếu hợp đồng cần. Dự án kéo dài vẫn liên kết original_source_year để không mất niên độ vốn.

## Thuật toán tổng hợp và kiểm tra

Tổng lũy kế kỳ = SUM(disbursed_cumulative_vnd) của sáu ô nguồn hợp lệ trong một report revision. CTMTQG là thuộc tính subset, không cộng vào tổng. Ví dụ: năm TW=100, năm ĐP=200, kéo dài TW=30, kéo dài ĐP=70, khác TW=0, khác ĐP=20 triệu → tổng 420 triệu. CTMTQG 40 triệu trong nhóm năm TW vẫn tổng 420, không phải 460.

Tổng danh mục tại as_of chọn revision accepted hiện hành của mỗi project+period theo chính sách snapshot. Báo cáo tuần 39 lũy kế 100 và tuần 40 lũy kế 150 cho cùng dự án thì số cuối tuần 40 là 150, không phải 250. Tăng kỳ = current cumulative − previous comparable cumulative; nếu âm, yêu cầu adjustment/reclassification và giải trình, không tự ép 0. Chuyển nguồn/kế hoạch mới phải chuẩn hóa scope trước so sánh.

Tỷ lệ giải ngân = SUM(actual) / SUM(allocated) × 100 trong cùng scope/snapshot. Mẫu số 0 → null + reason ZERO_DENOMINATOR. Tổng tỷ lệ của dự án 1 (50/100) và dự án 2 (90/900) là 140/1000=14%, không phải trung bình 30%. Distinct count cần set union hoặc aggregate sketch có sai số công bố; không cộng số người của các nhóm chồng lấn.

Các kiểm tra: required field; format/scale; CTMTQG ≤ source parent; source_year hợp lệ; period open; project scope; plan effective; revision current; amount anomalies. Hard validation khác warning: CTMTQG vượt parent chặn, khối lượng vượt kế hoạch có thể warning vì khác basis; warning override phải lưu lý do nếu policy yêu cầu.

## Giao dịch gửi báo cáo và cạnh tranh

BEGIN → SET LOCAL tenant context → SELECT report FOR UPDATE → kiểm membership/action/license kỳ hạn mới nhất → kiểm status/version → validate fields và references → persist immutable submission snapshot/hash → increment version → insert audit → insert outbox report.submitted → COMMIT. Dispatch notification xảy ra sau commit. Nếu outbox worker lỗi, báo cáo vẫn Submitted; retry không gửi trùng logical event.

PATCH dùng If-Match version; mismatch trả 409 VERSION_CONFLICT với current_version và safe diff. Submit/approve/payment request/license issue dùng Idempotency-Key và lưu request_hash/result trong TTL phù hợp. Transaction retry chỉ cho lỗi serialization/deadlock, cap số lần và không lặp side effect ngoài DB trong transaction. Lock allocation balance khi kiểm trần ngân sách.

## API convention và lỗi

Base /api/v1. OIDC bearer token; server lấy tenant context từ membership + tenant selection đã xác thực. Header X-Tenant-ID chỉ là đề nghị chọn tenant, không là bằng chứng quyền. Commands POST /reports/{id}/submit, /review, /amend; không dùng PATCH status tùy ý. GET /metrics/{id}/query nhận bộ lọc và snapshot qua query job POST nếu payload dài. Pagination cursor opaque/signed, page_size cap 200. Error envelope chuẩn theo OpenAPI Problem: type, title, status, code, correlation_id; detail, errors[{field,code,message}] và retryable là tùy chọn. Không dùng message/field_errors khác schema trong adapter trả về client.

Mã lỗi: 400 INVALID_REQUEST; 401 SESSION_EXPIRED; 403 SCOPE_DENIED/ENTITLEMENT_DENIED; 404 RESOURCE_NOT_FOUND trong scope; 409 VERSION_CONFLICT/IDEMPOTENCY_CONFLICT/PERIOD_LOCKED; 422 VALIDATION_FAILED; 429 RATE_LIMIT/BUDGET_EXCEEDED theo contract; 503 PROVIDER_UNAVAILABLE. Không dùng 402 như bảo mật duy nhất; entitlement service trả lý do cụ thể an toàn cho UI. Signed download URL kiểm quyền lại trước cấp.

## Dữ liệu và lifecycle AI

analysis_run liên kết tenant/project/package/criteria_version/profile_version/status/budget_reservation_id. analysis_attempt gồm run_id, ordinal, provider_request_id, actual_model, pricing_version, input_tokens, cached_tokens, output_tokens, reasoning_tokens_info, tool_units, latency_ms, original_currency, cost, reconcile_status. finding gồm criterion_id, status, text, evidence_refs và reviewer decision. evidence gồm document_version_id, page_index, bbox, snippet_hash và retrieval_score chỉ phục vụ debug được phân quyền.

Reserve: transaction khóa budget counters ở thứ tự tenant→unit→project→user; available = limit − settled − open_reservations. Ước tính tối đa theo input bound, output cap, tool cap, fallback cap; không đủ thì reject hoặc yêu cầu phê duyệt tăng giới hạn. Khi settle dùng actual provider usage, release phần dư; actual cao hơn reserve đưa exception và ngăn job tiếp theo theo policy, không sửa hóa đơn để khớp giả. Reservation timeout chỉ release sau reconcile hoặc quyết định có audit.

Pricing row có model, modality, meter, unit_size, price, currency, effective_from/to, source_url, verified_by. Token cached nằm trong input_total của một số provider: normalized noncached = input_total − cached; adapter phải khai báo semantics. Reasoning là breakdown của output nếu provider quy định như vậy, không cộng hai lần. Test bằng fixture có cache/reasoning/retry/tool và invoice rounding.

Guardrail: classify trước export dữ liệu ra provider; redact PII phù hợp mục đích; allowlist file và công cụ; structured output validate JSON schema; kiểm dẫn chứng tồn tại trong đúng document version. Model refusal/timeout/invalid JSON phải có trạng thái riêng. Không lưu chain-of-thought ẩn; lưu input/output phù hợp retention và giải thích có nguồn do hệ thống tạo.

## Notification và omnichannel chi tiết

event_id + tenant + event_version định danh domain event. notification_instance có workflow_version, recipient, purpose, dedupe_key, expires_at. delivery_attempt có channel_account_id, provider_message_id, status, error_code, attempt_no, next_retry_at, accepted/delivered/read timestamps, cost meter. Consent và preferences được snapshot cho audit nhưng quyền hiện thời kiểm lại trước gửi.

Webhook inbox lưu raw_payload_hash, provider_event_id, received_at, signature_valid, processing_status. Xác thực signature theo provider, reject body sửa; dedupe index tenant/provider/event_id. Callback monotonic reducer cho các trạng thái đã biết; callback chưa biết provider_message_id giữ pending mapping, không bỏ lặng. Received read không thay nghĩa business acknowledged. Nếu cancel sau ProviderAccepted, trạng thái cancel_requested, không báo đã hủy nếu provider không hỗ trợ.

Retry lịch đề xuất 30 s, 2 m, 10 m, 30 m với jitter và provider Retry-After; cap 5 lần và không vượt expires_at. Cấu hình phải điều chỉnh theo provider. DLQ replay không bypass suppression, opt-out, license hoặc data access. Outbound bảo mật dùng deep link chỉ chứa opaque resource ID, không token truy cập dài hạn.

## Tenant SaaS và license chi tiết

Tenant status [Provisioning,Active,Suspended,Offboarding,Archived]; subscription status theo billing lifecycle; license status theo FRD; resource access quyết định từ policy kết hợp, không đồng nhất payment_failed với revoked. Tenant domain uniqueness toàn platform; kiểm TXT trước enable và kiểm tiếp khi chuyển owner. Không nạp branding trước xác minh origin bằng nội dung tùy ý. HTML email/template sandbox và escape biến.

License payload ký bất đối xứng chứa issuer, tenant_id, license_id, revision, valid_from/until, grace_until, entitlements_hash, quota, deployment binding khi Private, key_id. Giữ private key tại KMS/HSM; verify bằng public key; rotation có overlap và revoked_key list. SaaS kiểm entitlement service online; cache TTL đề xuất 60 giây với invalidation event. Revocation hard-deny trong lần refresh kế tiếp; hành động rủi ro cao kiểm online trực tiếp.

Billing ledger dùng meter_event idempotent và invoice_line snapshot. Chuyển gói có preview proration theo điều khoản; sửa billing không sửa usage gốc. Thanh toán ngân hàng/cổng thanh toán có reconciliation và approval cho manual adjustment. Thời hạn license và subscription không nhất thiết bằng nhau vì hợp đồng mua sắm trả chậm; cần policy rõ, không tự gia hạn theo email hay chat.

## DrillContext và query security

Context gồm tenant_id, subject_scope_hash, metric_id/version, dataset_snapshot, filters AST, dimensions/path, unit/currency và as_of. Context token ký hoặc ID server-side, không tin JSON client tự sửa. Một drill request phải xác minh membership hiện tại rồi giao scope cũ với scope hiện tại; quyền bị thu hồi có hiệu lực ngay cả khi snapshot cũ vẫn còn.

Query compiler cho phép field IDs có trong semantic model, join path đã duyệt, operator allowlist và parameterized predicates. Áp tenant filter vào mọi bảng/join; tránh many-to-many fanout bằng grain và bridge

weighting được khai báo. Ratio trả numerator/denominator để UI giải thích. Pagination drill có stable ordering; sum pagination lấy query aggregate riêng, không chỉ tổng trang đang xem. Export cap/hàng đợi và watermark scope.

## Mobile sync protocol

Local draft envelope gồm tenant_id, user_id, device_id, local_uuid, base_server_version, changed_fields, attachment hashes, created_at và schema_version. Hàng đợi lưu encrypted, xác thực thiết bị từ secure storage. Sync POST /sync/batches có idempotency key từng item; trả accepted/conflict/rejected theo item, không fail cả batch vì một lỗi. Upload resumable chunks checksum; file chỉ liên kết báo cáo sau scan thành công.

Conflict field-level đối với nháp; số tiền không last-write-wins tự động. UI hiển thị bản máy, bản server, chênh lệch và lựa chọn; server revalidate sau merge. Không sync action approve/submit từ cache khi quyền/kỳ/license chưa kiểm online. Logout hoặc đổi tenant xóa cache/draft theo lựa chọn bảo mật và cảnh báo trước mất nháp; không đưa draft A sang B.

## Kiểm thử và quan sát

Unit tests cho công thức nguồn/CTMTQG/tỷ lệ/lũy kế và thời điểm license. Integration tests transaction submit/outbox/idempotency và allocation race. Security tests tenant B qua URL/body/search/vector/export/cache/webhook/job; object storage path traversal; IDOR; quyền revoked giữa query và download. AI tests prompt injection trong tài liệu, OCR sai số, missing evidence, criterion version mismatch, cost concurrency. Notification tests callback duplicate/out-of-order/unknown, provider timeout, consent revoked và DST/quiet hours.

Contract tests adapter Kho bạc/LLM/channel với fixtures đã anonymize. E2E web/mobile cho nháp → gửi → trả lại → sửa → accept → drill. Performance theo mô hình BRD và tenant noisy-neighbor; failover test broker/provider/DB replica. Observability trace xuyên request→outbox→worker→provider, có correlation_id và tenant nhưng không log secrets. Chỉ đóng UAT khi có bằng chứng kết quả và người chấp nhận.

## Theme & thương hiệu theo tenant — SAS-04

Chỉ System Admin được cấu hình thương hiệu cho các tenant: màu sắc, logo, menu, header, footer, tên hệ thống, địa chỉ và thông tin liên hệ. Tenant Admin chỉ được đọc cấu hình đã công bố của tenant mình, không được sửa, lưu nháp, tải logo, tạo review, áp dụng hoặc khôi phục. Các quyền quản trị nội bộ tenant khác không bao gồm quyền cấu hình thương hiệu.

Bản nháp tách biệt theo tenant và không thay đổi giao diện đang dùng. Xem trước web/smartphone trong vùng riêng; bước review hiển thị chênh lệch trước/sau, tenant đích và phiên bản gốc. Xác nhận áp dụng tạo phiên bản bất biến mới. Khôi phục cũng phải review và tạo phiên bản mới, giữ nguyên lịch sử. Kiểm tra trường bắt buộc, email, tệp logo và sáu cặp màu tương phản tối thiểu 4,5:1 trước khi công bố.

Server phải xác thực System Admin cho mọi lệnh ghi; không tin vai trò, tenant_id hoặc cờ quyền do trình duyệt gửi. Review gắn actor, tenant, hash nội dung, base version và hạn sử dụng. Kiểm tra lại quyền và phiên bản trong giao dịch công bố; trả 403 khi thiếu quyền, 409 khi xung đột, 422 khi cấu hình không hợp lệ. Audit ghi người thực hiện, tenant, bản trước/sau, lý do khôi phục và thời điểm; không ghi bí mật vào log.

Prototype SAS-04 dùng localStorage và bộ chọn vai trò mô phỏng để kiểm tra trải nghiệm. Đây không phải hệ thống xác thực hoặc cách ly tenant thật. Chi tiết triển khai và tiêu chí nghiệm thu nằm tại 03_Engineering/Tenant_Theme_Specification.html.

## Hợp đồng chi tiết và điều kiện đưa vào sprint

Bổ sung theme endpoints, entity schema và review token theo đặc tả tenant; public read không trả draft/history hoặc review token. Các generic resource endpoints trong OpenAPI vẫn là reference scaffolding: không triển khai mass assignment toàn schema, không dùng thay approve/publish/revoke. Trước coding mỗi action phải có operationId, DTO allowlist, If-Match/idempotency, policy và test oracle. Module_Implementation_Contracts và test_cases là checklist kiểm soát đầy đủ phạm vi, chưa chứng minh endpoint bindings đã được nghiệm thu.

Tài liệu điều phối: 09_Ke_hoach_trien_khai; 10_Ke_hoach_kiem_thu_va_chuyen_doi; 03_Engineering/Implementation_Backlog.html; 03_Engineering/Test_Case_Catalogue.html; 03_Engineering/Decision_Register.html.